

Week 6 · Task 1B – CAPSTONE – Full Pentest + Professional Report

PENETRATION TESTING CAPSTONE REPORT

Internal Network Penetration Test — TryHackMe "Basic Pentesting" Lab Environment

Target Environment	TryHackMe – Basic Pentesting room (basicpentestingjt)
Target IP Address	10.130.135.211
Attacker IP (AttackBox)	10.130.191.120
Assessment Dates	September 28, 2026 (03:45 – 04:18 UTC-equivalent lab session)
Tester	[NEHA REHAN] — Cybersecurity Capstone Candidate
Report Classification	Confidential — Educational / Portfolio Use Only

1. Executive Summary

This report documents a black-box penetration test performed against a single Linux host (10.130.135.211) hosted in TryHackMe's "Basic Pentesting" lab environment. The engagement was conducted to demonstrate a complete attack chain — from unauthenticated enumeration through to full compromise of a secondary user account — and to produce actionable remediation guidance, following the general structure used in publicly published professional penetration test reports.

Testing identified five findings spanning CRITICAL, HIGH, and MEDIUM severity. An anonymously-readable SMB share disclosed internal usernames, which were used to brute-force a weak SSH password. Once inside the box, a plaintext backup credential file and a weakly-passphrased SSH private key were both recovered and cracked offline, allowing full pivot to a second user account (kay) and demonstrating that a single low-effort entry point can cascade into complete account compromise. No findings required custom exploit development — all issues stemmed from configuration weaknesses and credential hygiene.

Overall Risk Rating: CRITICAL — immediate remediation of SSH authentication controls and secrets handling is recommended before this configuration pattern is used outside a lab context.

2. Scope of Assessment

In Scope

- Target host: 10.130.135.211 ("Web App Test" lab machine)
- Services: Samba/SMB (TCP 445), SSH (TCP 22)
- Testing style: Black-box, unauthenticated start, no credentials supplied by the client

Out of Scope

- Any host other than 10.130.135.211
- Denial-of-service testing
- Physical and social-engineering vectors

Rules of Engagement

All testing was conducted from the assigned attacker workstation (10.130.191.120) inside an isolated TryHackMe lab network, with no impact to production systems. All activity is timestamped from tool output for traceability.

3. Methodology

The assessment followed a standard four-phase penetration testing methodology, consistent with PTES (Penetration Testing Execution Standard):

- Reconnaissance & Enumeration — Identify exposed services and shares using smbclient.
 - Credential Attack — Brute-force SSH authentication with Hydra using a harvested username and the rockyou.txt wordlist.
 - Initial Access & Post-Exploitation — Authenticate over SSH, enumerate the filesystem, and harvest additional secrets (pass.bak, id_rsa).
 - Privilege / Lateral Movement — Crack the recovered SSH private key offline with John the Ripper and pivot to a second user account (kay), confirming full compromise.
-

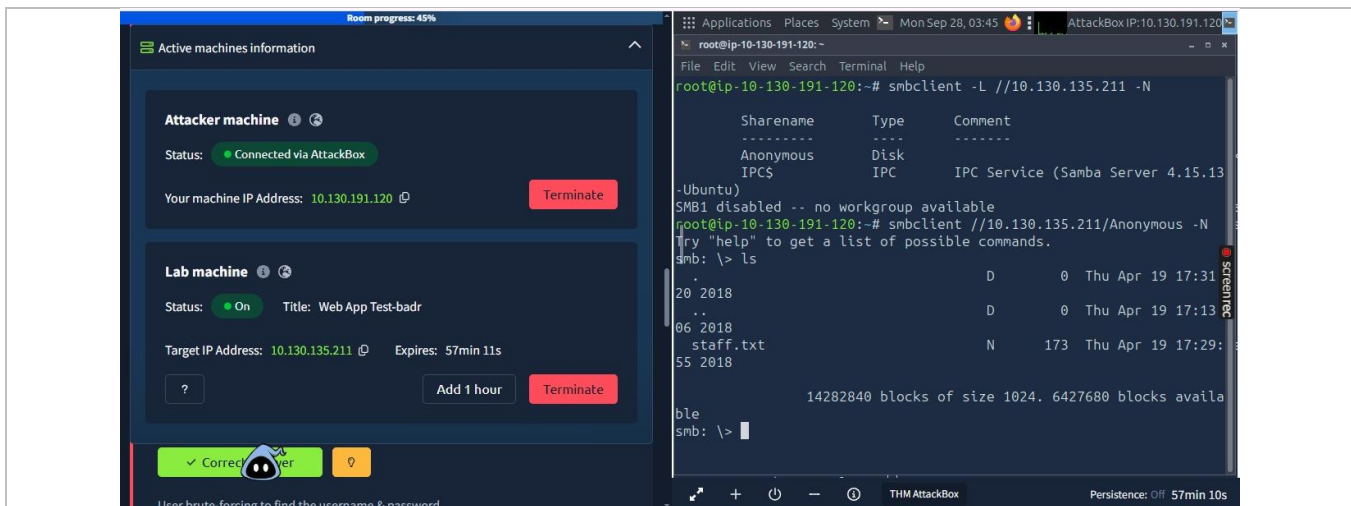
4. Summary of Findings

ID	Vulnerability	Severity	Affected Component	Status
VULN-01	Unauthenticated anonymous SMB share access	HIGH	Samba / SMB (TCP 445)	Exploited
VULN-02	Weak SSH password susceptible to online brute-force	CRITICAL	SSH (TCP 22)	Exploited
VULN-03	Plaintext backup credential file in user home directory	HIGH	Local filesystem (~/.pass.bak)	Exploited
VULN-04	Weakly-protected SSH private key passphrase, cracked offline	HIGH	id_rsa (SSH key)	Exploited
VULN-05	Outdated OS packages / unsupported ESM Infra stack	MEDIUM	Ubuntu OS core	Identified

5. Detailed Findings & Evidence

VULN-01 — Unauthenticated Anonymous SMB Share Access (HIGH)

An anonymous (null) SMB session was permitted against the target's Samba service, exposing a share named "Anonymous" without any authentication requirement.



Evidence 1 — smbclient null-session enumeration revealing the "Anonymous" share and staff.txt

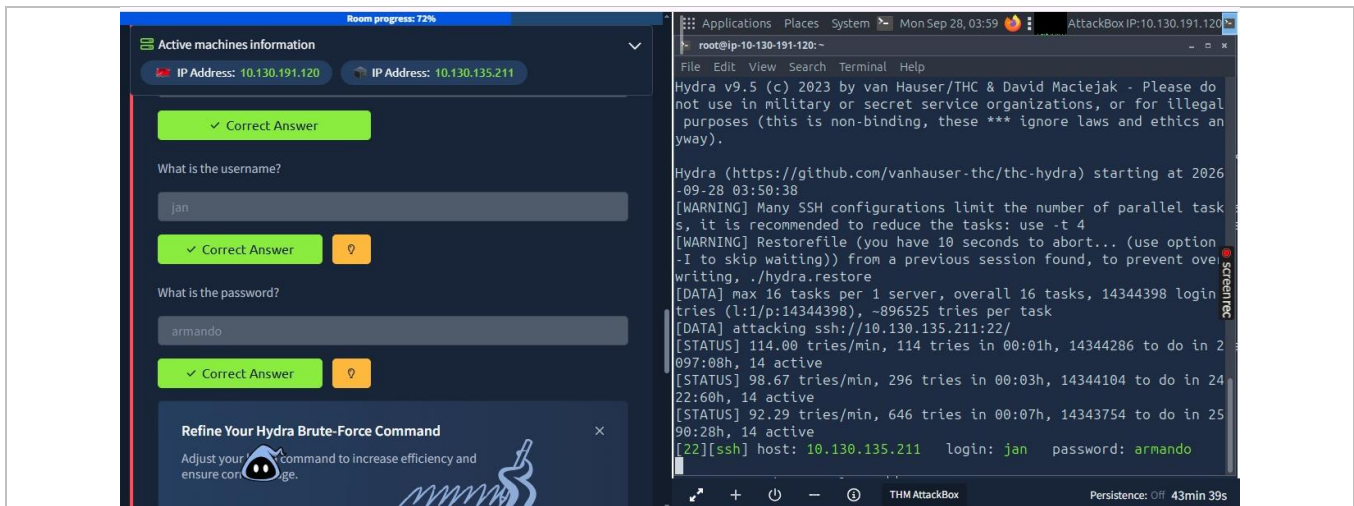
The share contained a file, staff.txt, listing internal usernames. This file directly disclosed the accounts jan and kay, which were then used as the basis for the credential attack in VULN-02.

Impact:

Anonymous share access allowed full reconnaissance of internal usernames with zero authentication, significantly lowering the effort required for a subsequent brute-force attack.

VULN-02 — Weak SSH Password / Successful Brute-Force (CRITICAL)

Using the username jan harvested from the SMB share, an online brute-force attack was launched against the SSH service with Hydra v9.5 and the rockyou.txt wordlist.



Evidence 2 — Hydra recovering valid SSH credentials jan:armando within minutes

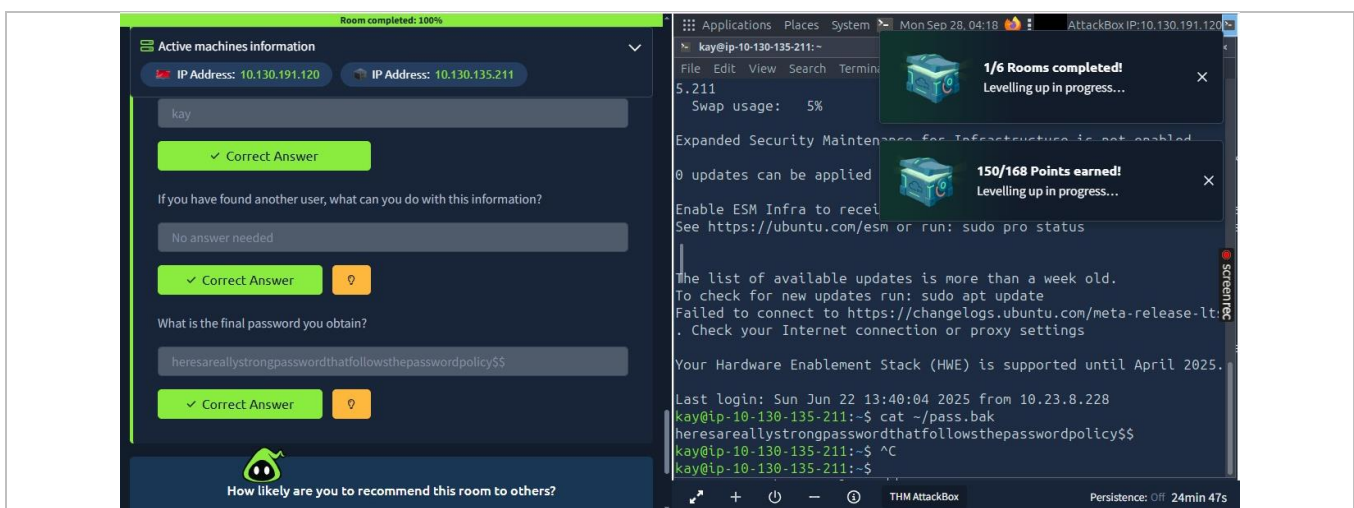
The attack recovered a valid, weak credential pair (jan : armando) in a short time window, granting an interactive SSH session on the target.

Impact:

A single weak password provided full interactive shell access as user jan, forming the initial-access foothold for the remainder of the engagement.

VULN-03 — Plaintext Backup Credential File (HIGH)

Post-exploitation enumeration of the filesystem as user jan uncovered a plaintext backup password file, pass.bak, inside user kay's home directory, along with an id_rsa private key.



Evidence 3 — pass.bak read directly as user kay, disclosing a plaintext password

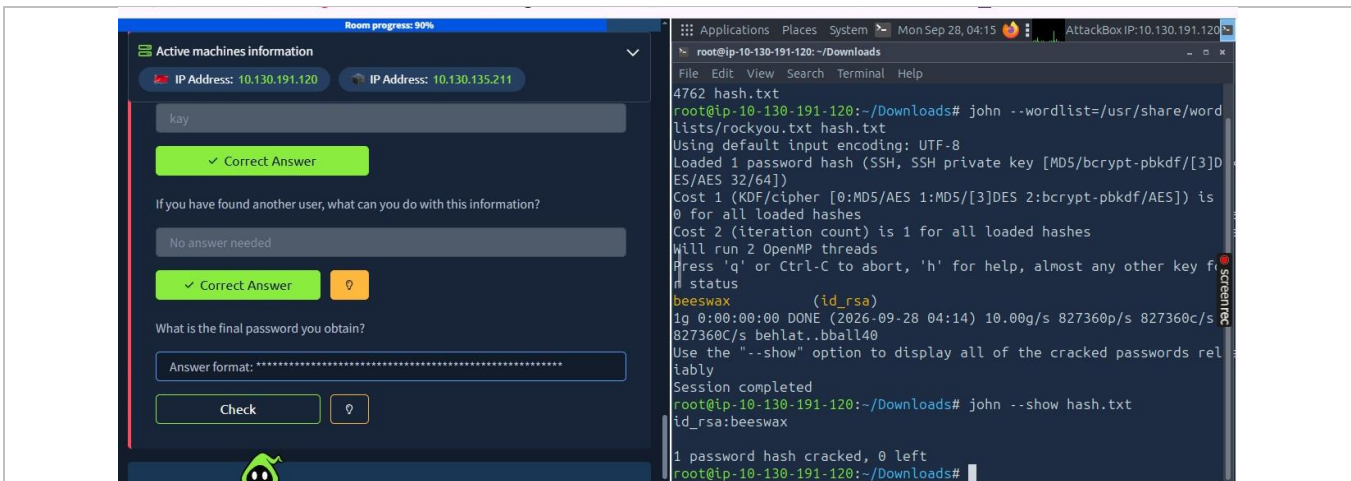
Reading the file directly returned kay's plaintext password (heresareallystrongpasswordthatfollowsthepasswordpolicy\$), confirming vertical account access without needing to crack any hash for this particular route.

Impact:

Storing credentials unencrypted on disk bypasses all authentication controls; anyone with local read access — even a low-privileged, freshly-compromised account — can escalate to another user instantly.

VULN-04 — Weakly-Protected SSH Private Key (HIGH)

An SSH private key (`id_rsa`) recovered from the target's filesystem was protected by a passphrase. The key was extracted and its hash format identified, then cracked offline using John the Ripper against the `rockyou.txt` wordlist.



Evidence 4 — John the Ripper cracking the `id_rsa` passphrase (beeswax) in under one second

The key's passphrase (beeswax) was recovered almost instantly, since it exists in a common wordlist. This provided an alternate, persistent authentication path to the target independent of the SSH password itself.

Impact:

A crackable private-key passphrase defeats the added protection key-based authentication is meant to provide, and gives an attacker a durable credential that survives password rotations unless the key is also revoked.

VULN-05 — Outdated OS Packages / Unsupported ESM Stack (MEDIUM)

Login banners on the target repeatedly reported that Expanded Security Maintenance (ESM) Infrastructure was not enabled, that the Hardware Enablement (HWE) stack was approaching end-of-support, and that the system could not reach Ubuntu's changelog servers to check for updates.

Impact:

An unpatched, unsupported OS baseline increases exposure to any future kernel or package-level vulnerability and indicates the host is not part of a routine patch-management cycle.

6. Risk Assessment

The five findings form a single, complete attack chain rather than isolated issues: SMB disclosure (VULN-01) supplied the username used in the SSH brute-force (VULN-02); that foothold exposed both a plaintext credential file and an SSH key (VULN-03, VULN-04), either of which independently granted access to a second account. The presence of two separate, unrelated weak-secret failures (a guessable account password and a guessable key passphrase) suggests a systemic weakness in credential-hygiene practices rather than a one-off misconfiguration. Combined with an unpatched OS (VULN-05), the target presents a CRITICAL overall risk profile.

7. Remediation Plan

Category	Deficiency Identified	Recommended Remediation
SMB Hardening	Anonymous read access allowed on Samba share.	Disable null sessions in <code>/etc/samba/smb.conf</code> (set "map to guest = Bad User") or remove guest access entirely from sensitive shares.
SSH & Auth	Weak user password ("armando") vulnerable to brute-force.	Enforce a strong password policy (14+ chars, complexity) and migrate to key-based SSH authentication with PasswordAuthentication no in <code>sshd_config</code> .
Brute-Force Defense	Unrestricted authentication attempts on SSH.	Deploy Fail2ban or iptables rate-limiting to lock out source IPs after repeated failed logins.
Secrets Management	Plaintext password file (pass.bak) stored on disk.	Delete plaintext credential backups immediately; adopt a secrets manager (HashiCorp Vault, AWS Secrets Manager) for credential storage.
SSH Key Hygiene	Private key (id_rsa) protected by a weak, wordlist-guessable passphrase.	Regenerate SSH key pairs with high-entropy passphrases (or none, relying on agent + hardware key), rotate any key exposed during testing, and restrict key file permissions (600).
OS Maintenance	Outdated packages and unsupported HWE/ESM stack.	Upgrade to a currently-supported Ubuntu LTS release, enable Extended Security Maintenance, and apply patches on a defined cadence.

8. Conclusion

This engagement demonstrated a complete, low-complexity compromise chain — from anonymous SMB enumeration through SSH brute-force to full credential and private-key recovery — without requiring any custom exploit code. Every finding traces back to a preventable configuration or credential-hygiene failure. Implementing the remediation plan in Section 7, particularly disabling anonymous SMB access, enforcing key-based SSH authentication with strong passphrases, and eliminating plaintext secrets from disk, would close the entire attack path documented in this report.

This report was produced as part of a cybersecurity capstone exercise and follows the general structure and layout conventions used in publicly available professional penetration test reports (e.g., the [juliocesartfort/public-pentesting-reports](#) reference collection), adapted for a single-host lab engagement.

Share your win with your peers

Your progress can inspire others in your community.



Basic Pentesting completed!

neharehan2020 completed another room on their cyber security journey.

Completed tasks

1

Points earned

180

Streak

16

Share on social media

Share your win before starting the next room

in LinkedIn

WhatsApp

Telegram

Twitter / X

Facebook

Reddit

Go to dashboard →

public-pentesting-reports Public

Watch 516

Fork 2.2k

Star 9.7k

master 1 Branch 0 Tags

Go to file

Add file

Code

juliocezarfort	Create GlobaLeaks-2024-isgroup.pdf	df4fe26 · 3 months ago	245 Commits
7ASecurity	Merging 7ASecurity and Assured AB reports	4 months ago	
ADALogics	Added reports from ADA Logics, ROS, ToB and others	4 years ago	
AssuredAB	Merging 7ASecurity and Assured AB reports	4 months ago	
Atredis	Adding Atredis and LeastAuthority	3 years ago	
Bishop Fox	Add files via upload	5 years ago	
BlazeInformationSecurity	Adding Blaze Information Security and Trail of Bits	7 years ago	
Bugcrowd	Add reports from Instructure's public security reports	5 years ago	
COMSATS_Islamabad-CyberSecurityLab	Create Threat_Modeling_Trinity_Wallet.pdf	6 years ago	
CPTC	Add files via upload	4 years ago	

About

A list of public penetration test reports published by several consulting firms and academic security groups.

Readme

Activity

9.7k stars

516 watching

2.2k forks

Report repository

Releases

No releases published

Packages

Sample Pentest Reports